Informe de Pentesting
Actividad A08 — Hacking Etico

Cliente: **INSECUR S.A.** — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Informacion
Licenciatura en Sistemas de Informacion — Facultad de Informatica y Diseno
Docente: Ing. Rodrigo Atilio Elgueta

Alumno: **Leonardo Cangialosi**

Branch: `cangialosi-leonardo`

Ciclo Academico Vigente

Indice

1 Datos generales **2**

2 Pre-pentesting **2**

3 Durante: Hallazgos por fase **3**
3.1 Nucleo obligatorio: Pentesting Fundamentals 3
3.2 Nucleo obligatorio: Basic Pentesting 3
3.3 Sala de eleccion: Vulnversity 16

4 Resumen ejecutivo de hallazgos **23**

5 Post-pentesting: Recomendaciones **23**

6 Protocolo de contingencia **24**

7 Anexos **25**

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Leonardo Cangialosi
DNI	.....
Username TryHackMe	.....
Email institucional	leocangialosi04@gmail.com
Sala de eleccion (Nivel 2)	Vulnversity
Branch en GitHub	`cangialosi-leonardo`
Fecha de inicio	.....
Fecha de cierre	.....

2. Pre-pentesting

Alcance del trabajo

El alcance de esta intervencion comprende exclusivamente los entornos de laboratorio provistos por la plataforma TryHackMe, asignados en la guia de la catedra:

- Sala obligatoria: **Pentesting Fundamentals** (metodologia).
- Sala obligatoria: **Basic Pentesting** (enumeracion, explotacion y escalada de privilegios).
- Sala de eleccion: **Vulnversity** (enumeracion de servicios, explotacion web y escalada de privilegios en Linux).

Quedan excluidos del alcance cualquier sistema, red o servicio que no sea provisto explicitamente por TryHackMe dentro de estas salas. No se realizo ninguna accion contra sistemas de produccion ni activos reales de terceros.

Reglas de Enfrentamiento (ROE)

- Las pruebas se ejecutan unicamente contra la IP asignada por TryHackMe a traves de la VPN oficial de la plataforma.
- No se realizan ataques de denegacion de servicio (DoS) ni se satura el ancho de banda del laboratorio.
- Toda herramienta de fuerza bruta (p. ej. Hydra) se usa con limite de hilos razonable y unicamente sobre los servicios habilitados por la sala.
- Ante cualquier incidente o comportamiento inesperado de la maquina, se detiene la prueba y se notifica al docente.
- No se publican flags en texto plano; se reportan como hash SHA-256 (ver Anexo C).

Autorizacion

Declaro que cuento con autorizacion expresa de la catedra de Seguridad Aplicada a Sistemas de Informacion (FID-UCH) para ejecutar tecnicas de pentesting unicamente sobre los entornos de laboratorio de TryHackMe indicados en la guia de la Actividad A08, en el marco del caso academico ficticio INSECUR S.A.

Metodologia utilizada

Se adopta como referencia metodologica el **PTES (Penetration Testing Execution Standard)**, complementado con la guia **OWASP Testing Guide** para los componentes web encontrados. Se elige PTES por su cobertura completa de las fases de pre-engagement, reconocimiento, escaneo, explotacion, post-explotacion y reporte, que coincide con la estructura exigida por la catedra.

3. Durante: Hallazgos por fase

3.1. Nucleo obligatorio: Pentesting Fundamentals

Sala completada al 100% (Tasks 1 a 5, incluyendo el practico ACME Penetration Test). Esta sala es teorico-practica introductoria y no involucra explotacion sobre una maquina propia; el entregable verificable es la flag del ejercicio practico.

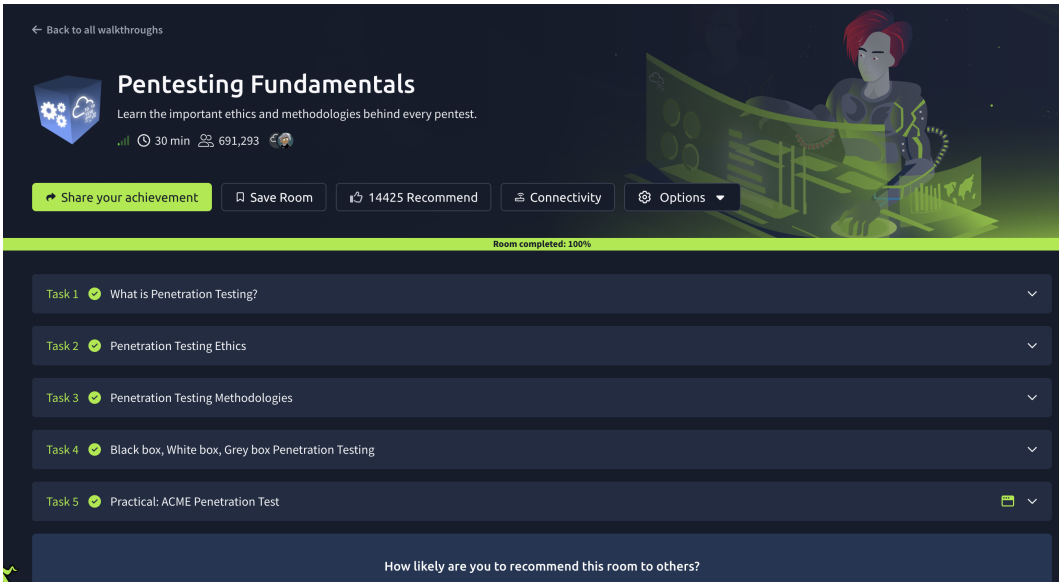


Figura 1: Sala Pentesting Fundamentals completada al 100%

Campo	Valor
Flag obtenida (practico ACME)	`SHA-256: 583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6`

3.2. Nucleo obligatorio: Basic Pentesting

Estado al cierre de esta version del informe: reconocimiento, escaneo y obtencion de credenciales de usuario **`jan`** *completados. Acceso SSH confirmado. Escalada de privilegios hacia el usuario* **`kay`** *y root en curso.*

Campo	Valor
ID del hallazgo	H-01

Fase	■ Reconocimiento ☐ Escaneo ☐ Explotacion ☐ Post-explotacion
Descripcion	Identificacion de la maquina objetivo (`10.67.168.50`) dentro del rango asignado por TryHackMe, diferenciandola de la IP de la propia AttackBox (`10.67.159.193`).
Componente afectado	Red de laboratorio THM
Herramienta utilizada	Panel "Active machines information" de la sala
Impacto en la Triada CIA	☐ Confidencialidad ☐ Integridad ☐ Disponibilidad

Campo	**Valor**
ID del hallazgo	H-02
Fase	☐ Reconocimiento ■ Escaneo ☐ Explotacion ☐ Post-explotacion
Descripcion	Escaneo de puertos y servicios con Nmap. Se detectan cuatro servicios expuestos: SSH, HTTP (Apache) y Samba (SMB) duplicado en TCP/139 y TCP/445.
Componente afectado	`10.67.168.50` (puertos 22, 80, 139, 445)
Categoria (OWASP / CWE)	CWE-200 (exposicion de informacion de version de servicios)
CVSS estimado	☐ Bajo ■ Medio ☐ Alto ☐ Critico
Evidencia (captura / comando)	`nmap -sC -sV 10.67.168.50` — ver `bitacora/nmap_inicial.txt` y Figura 2
Herramienta utilizada	Nmap 7.94SVN
Impacto en la Triada CIA	■ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir el banner-grabbing (ocultar version de Apache/OpenSSH/Samba), exponer unicamente los servicios estrictamente necesarios y segmentar SMB fuera de la red publica.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

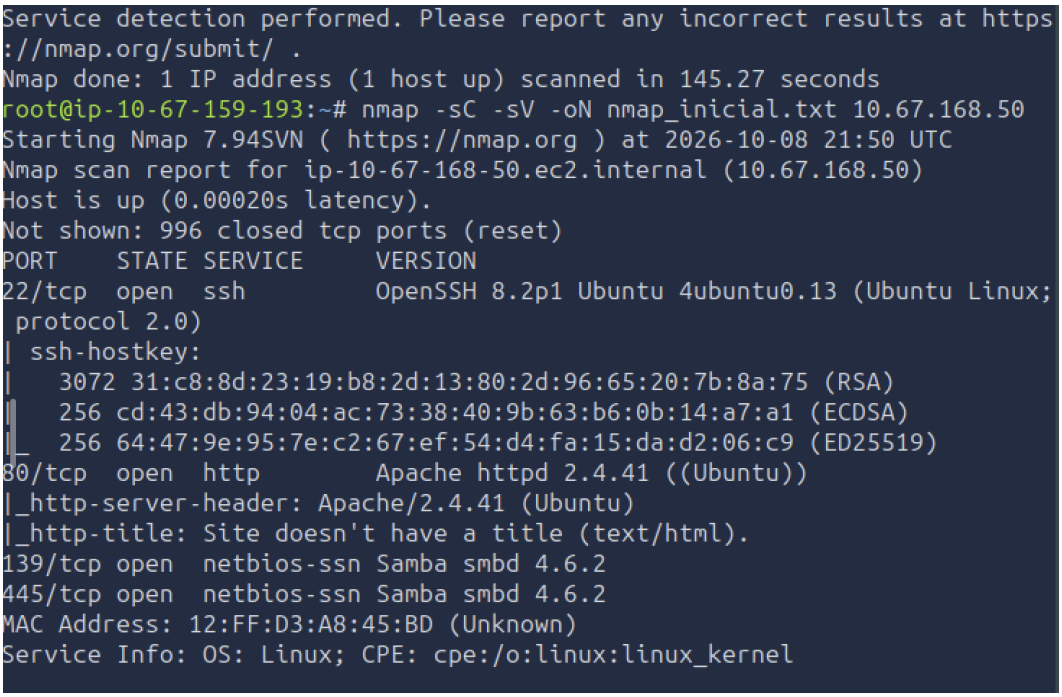


Figura 2: Resultado de Nmap sobre 10.67.168.50

Campo	**Valor**
ID del hallazgo	H-03
Fase	☐ Reconocimiento ■ Escaneo ☐ Explotacion ☐ Post-explotacion
Descripcion	Enumeracion de directorios web con Gobuster. Se descubre el directorio `/development` (listado abierto de Apache), que expone dos archivos de texto internos (`dev.txt` y `j.txt`) con notas de desarrollo y una referencia directa a un usuario del sistema.
Componente afectado	`http://10.67.168.50/development/`
Categoria (OWASP / CWE)	A05:2021 - Security Misconfiguration (directory listing habilitado); CWE-200
CVSS estimado	☐ Bajo ☐ Medio ■ Alto ☐ Critico
Evidencia (captura / comando)	`gobuster dir -u http://10.67.168.50 -w /usr/share/wordlists/dirb/common.txt` — ver `bitacora/gobuster.txt` y Figuras 3–6
Herramienta utilizada	Gobuster v3.6

Impacto en la Triada CIA	■ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Deshabilitar `Options +Indexes` en Apache, remover archivos de desarrollo/notas internas de directorios publicos y nunca versionar credenciales ni nombres de usuario en texto plano accesible via web.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

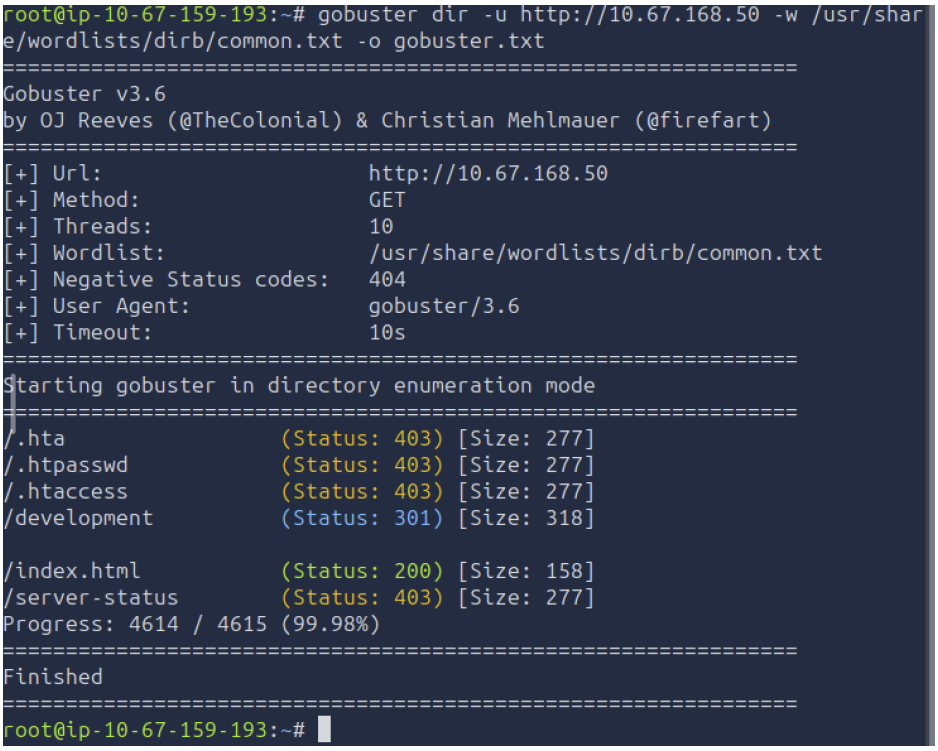


Figura 3: Gobuster descubre el directorio `/development`



Figura 4: Listado abierto de `/development/`: `dev.txt` y `j.txt`

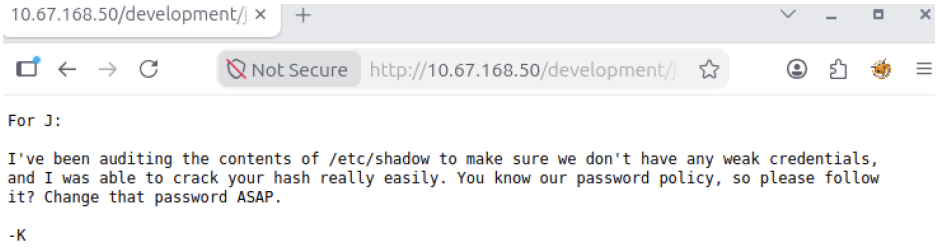


Figura 5: Contenido de `j.txt`: nota interna que confirma al usuario `jan` y revela que su contraseña fue auditada como debil

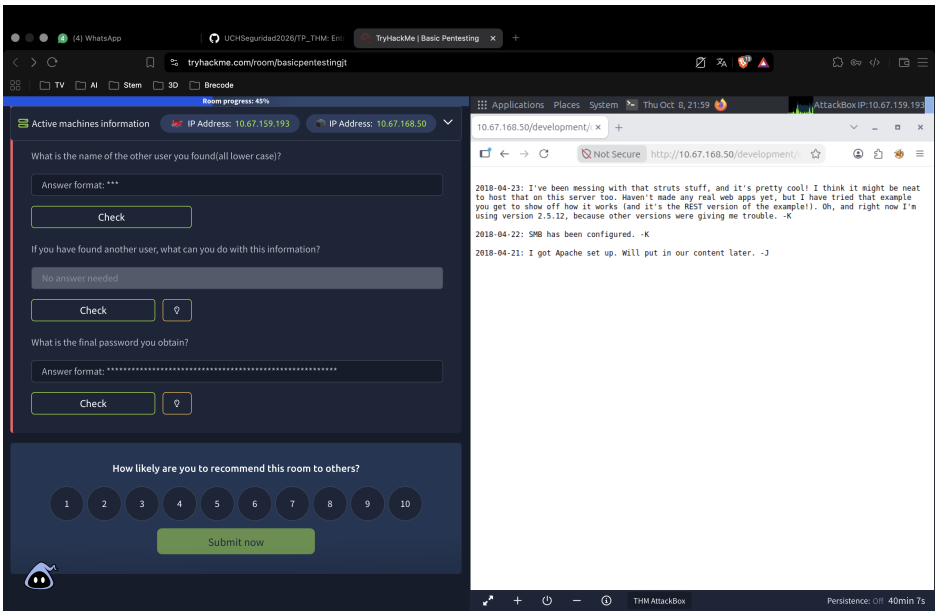


Figura 6: Contenido de `dev.txt`: bitacora de desarrollo que identifica al usuario `jan` y referencias de configuracion del servidor

Campo	**Valor**
ID del hallazgo	H-04
Fase	☐ Reconocimiento ☐ Escaneo ■ Explotacion ☐ Post-explotacion
Descripcion	A partir del usuario `jan` (obtenido en H-03), se realiza fuerza bruta contra el servicio SSH. Se obtiene una contraseña valida y se logra acceso remoto autenticado a la maquina.
Componente afectado	SSH (TCP/22) en `10.67.168.50`, cuenta `jan`
Categoria (OWASP / CWE)	CWE-521 (contraseña debil); CWE-307 (falta de proteccion ante intentos excesivos de autenticacion)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ■ Critico
Evidencia (captura / comando)	`hydra -l jan -P <wordlist> 10.67.168.50 ssh -t 16` — ver `bitacora/hydra_jan.txt` y Figuras 7–8
Herramienta utilizada	THC-Hydra
Impacto en la Triada CIA	■ Confidencialidad ■ Integridad ☐ Disponibilidad

Salvaguarda propuesta	Politica de contraseñas robustas (longitud minima, complejidad, no reutilizacion), autenticacion por clave publica en lugar de password para SSH, y bloqueo/throttling de intentos fallidos (fail2ban o equivalente).
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

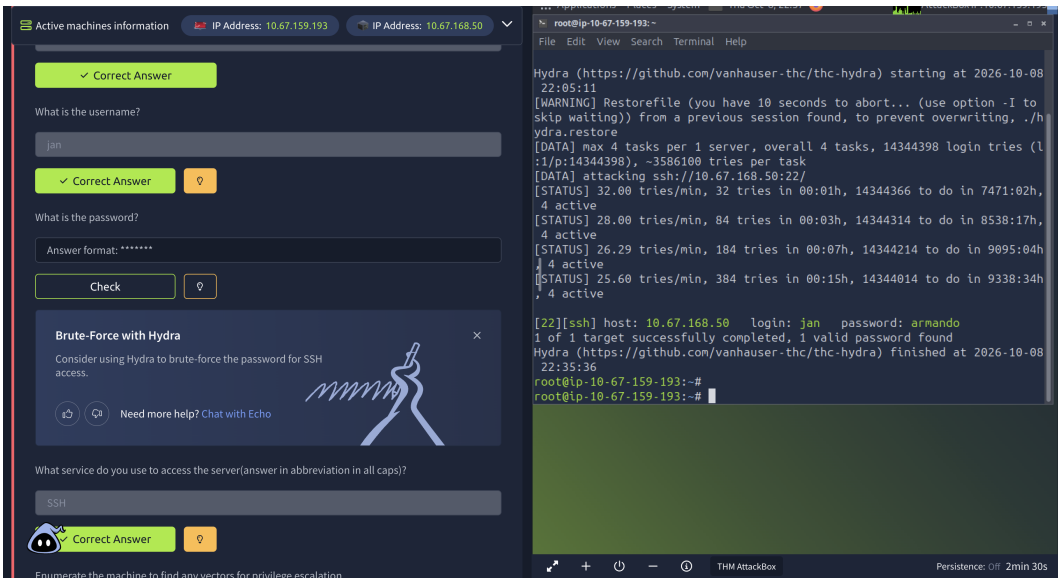


Figura 7: Hydra obtiene la contraseña de `jan` por fuerza bruta contra SSH

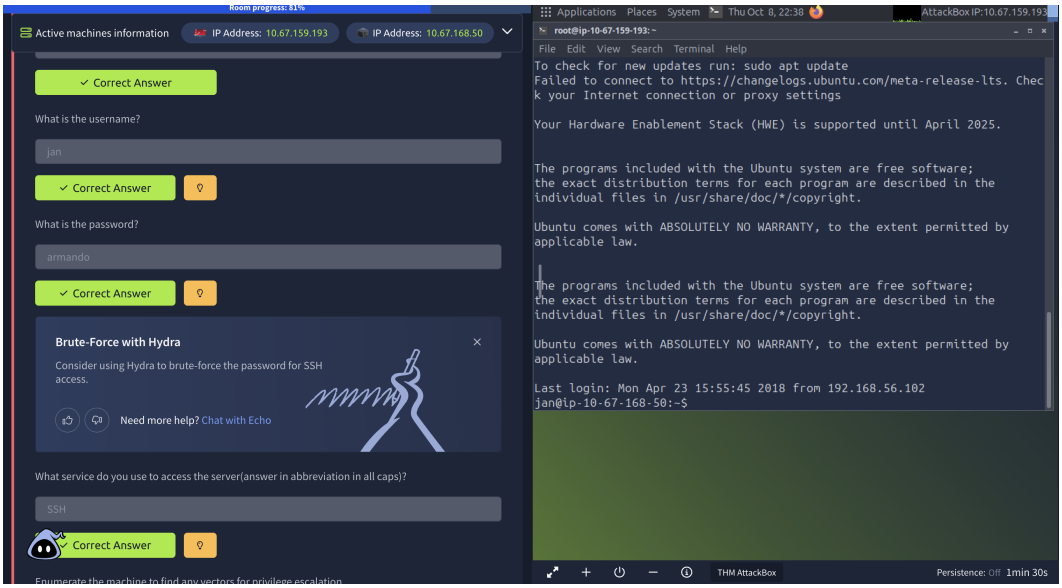


Figura 8: Acceso SSH exitoso como `jan` en `10.67.168.50`

Campo	**Valor**
ID del hallazgo	H-05

Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotacion ■ Post-explotacion
Descripcion	Enumerando como `jan`, se detecta que el directorio home de `kay` (`/home/kay`) tiene permisos `755` y su subcarpeta `.ssh` tambien es de lectura abierta. Esto permite leer la clave privada SSH de `kay` (`id_rsa`) sin ser su propietario, aunque la clave esta protegida con passphrase (AES-128-CBC).
Componente afectado	`/home/kay/.ssh/id_rsa`
Categoria (OWASP / CWE)	CWE-732 (asignacion incorrecta de permisos para un recurso critico)
CVSS estimado	☐ Bajo ☐ Medio ■ Alto ☐ Critico
Evidencia (captura / comando)	`ls -la /home/kay/`; `cat /home/kay/.ssh/id_rsa` — Figuras 9–10
Herramienta utilizada	Bash (enumeracion manual)
Impacto en la Triada CIA	■ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Aplicar permisos `700` a todos los directorios home y `600`/`700` a `~/.ssh` y su contenido; revisar periodicamente permisos de archivos sensibles con herramientas de hardening (CIS Benchmarks).
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

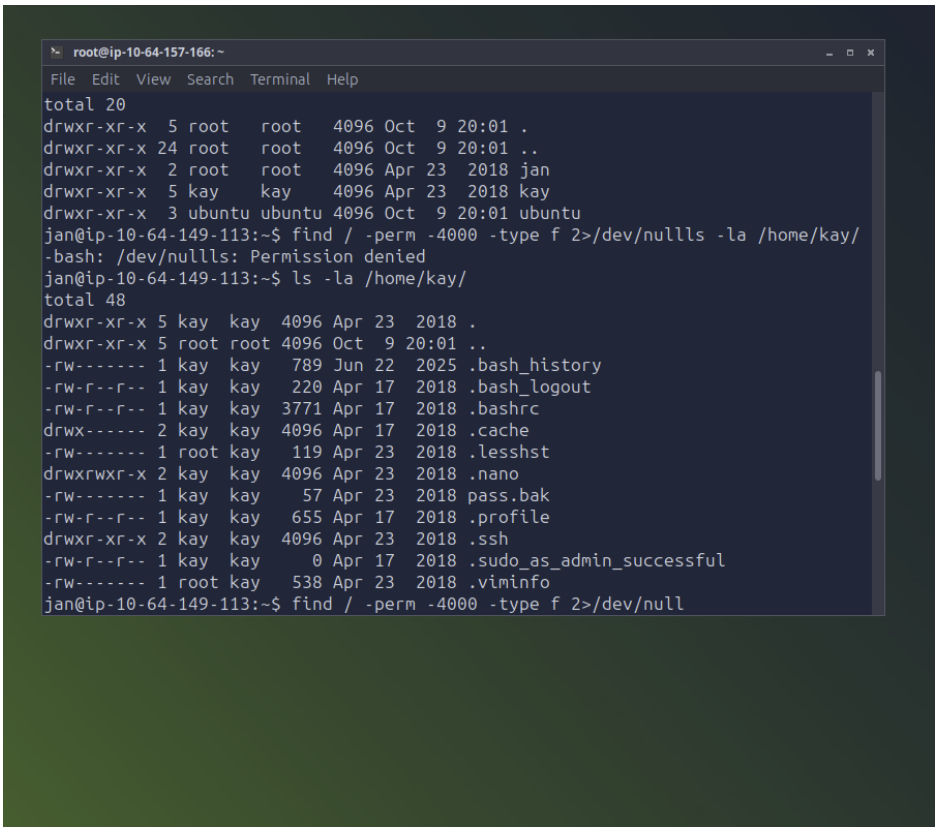


Figura 9: Listado de `/home/kay/` accesible desde la cuenta `jan`

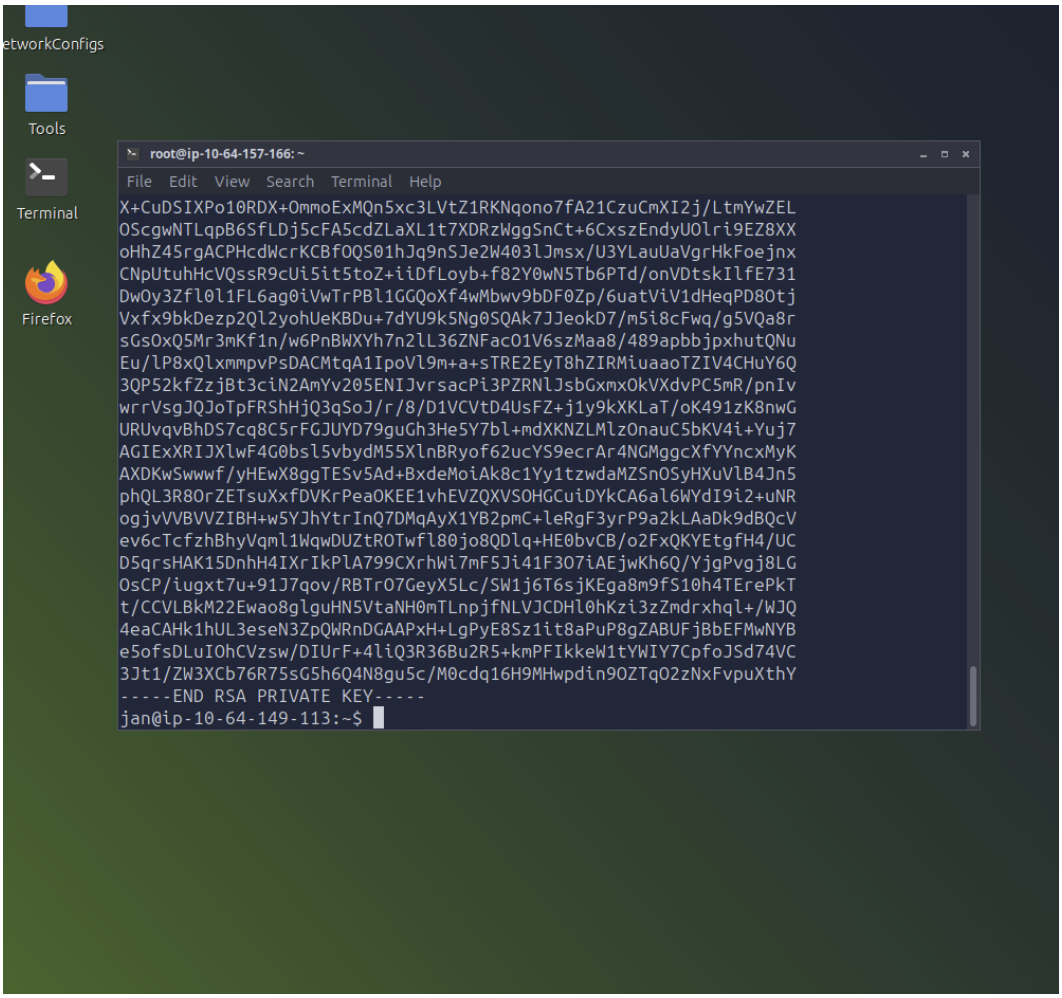


Figura 10: Clave privada SSH de `kay` extraida (cifrada con passphrase)

Campo	**Valor**
ID del hallazgo	H-06
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotacion ■ Post-explotacion
Descripcion	La clave privada obtenida en H-05 se transfiere a la AttackBox y se convierte con `ssh2john` para crackeo offline con John the Ripper contra `rockyou.txt`. Se obtiene la passphrase de la clave, lo que permite autenticarse como `kay` via SSH.
Componente afectado	SSH (TCP/22), cuenta `kay`
Categoria (OWASP / CWE)	CWE-521 (passphrase debil, presente en diccionario de contrasenas filtradas)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ■ Critico

Evidencia (captura / comando)	`ssh2john kay_id_rsa > kay_hash.txt; john -wordlist=rockyou.txt kay_hash.txt` — ver `bitacora/enum4linux.txt` y Figuras 11–12
Herramienta utilizada	John the Ripper
Impacto en la Triada CIA	■ Confidencialidad ■ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Exigir passphrases de alta entropia para claves SSH (no presentes en diccionarios publicos), y complementar con autenticacion multifactor para accesos administrativos.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

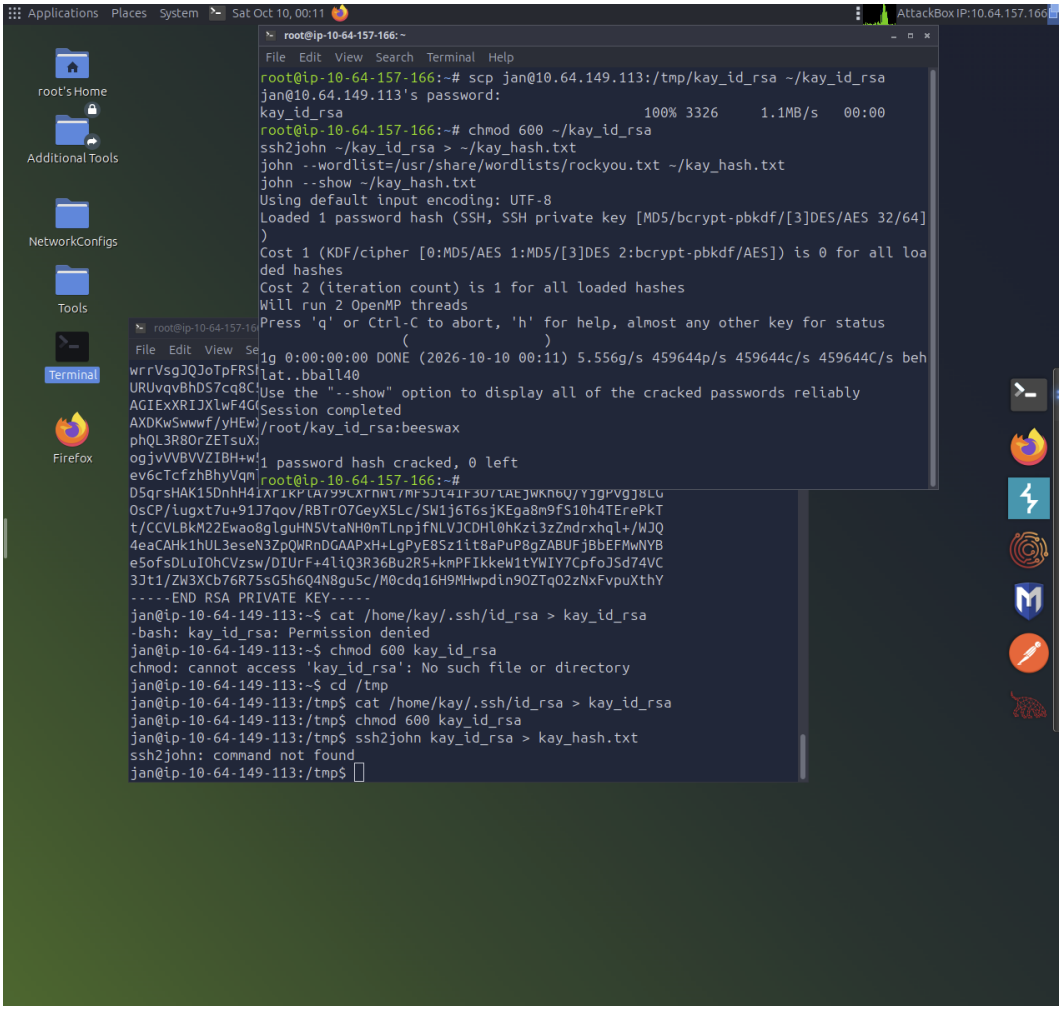


Figura 11: John the Ripper obtiene la passphrase de la clave de `kay`: `beeswax`

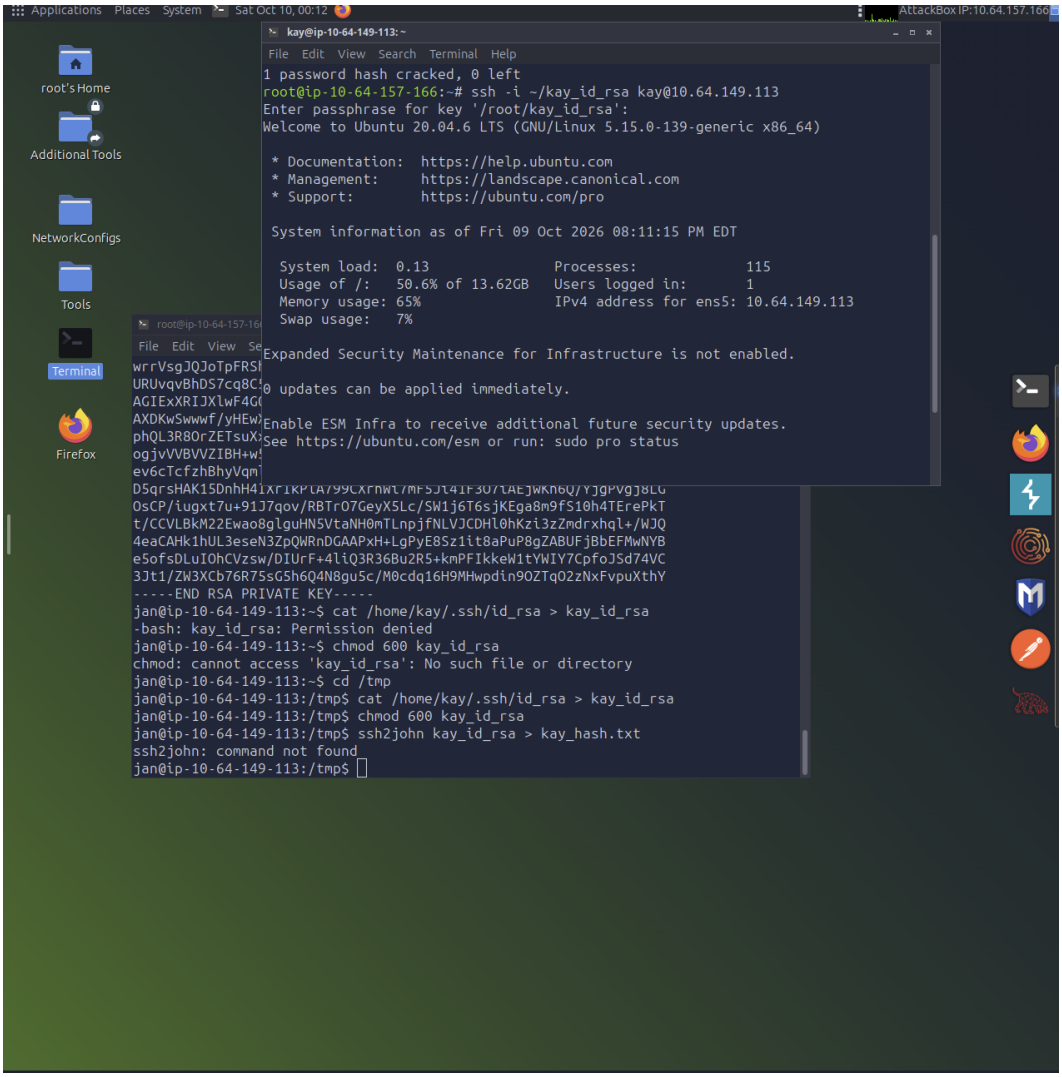


Figura 12: Acceso SSH exitoso como `kay` utilizando la clave privada y su passphrase

Campo	**Valor**
ID del hallazgo	H-07
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotacion ■ Post-explotacion
Descripcion	Dentro del home de `kay` existe un archivo `pass.bak` con permisos restringidos al propietario (`600`), ilegible por `jan` pero accesible una vez autenticado como `kay`. Contiene una contrasena en texto plano, posiblemente un respaldo olvidado de una politica de contrasenas anterior.
Componente afectado	`/home/kay/pass.bak`
Categoria (OWASP / CWE)	CWE-312 (almacenamiento de credenciales en texto plano)

CVSS estimado	☐ Bajo ☐ Medio ■ Alto ☐ Critico
Evidencia (captura / comando)	`cat /home/kay/pass.bak` — Figura 13
Herramienta utilizada	Bash
Impacto en la Triada CIA	■ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Eliminar respaldos de credenciales en texto plano; utilizar gestores de secretos (Vault, gestor de contrasenas corporativo) en lugar de archivos sueltos en el sistema de archivos.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

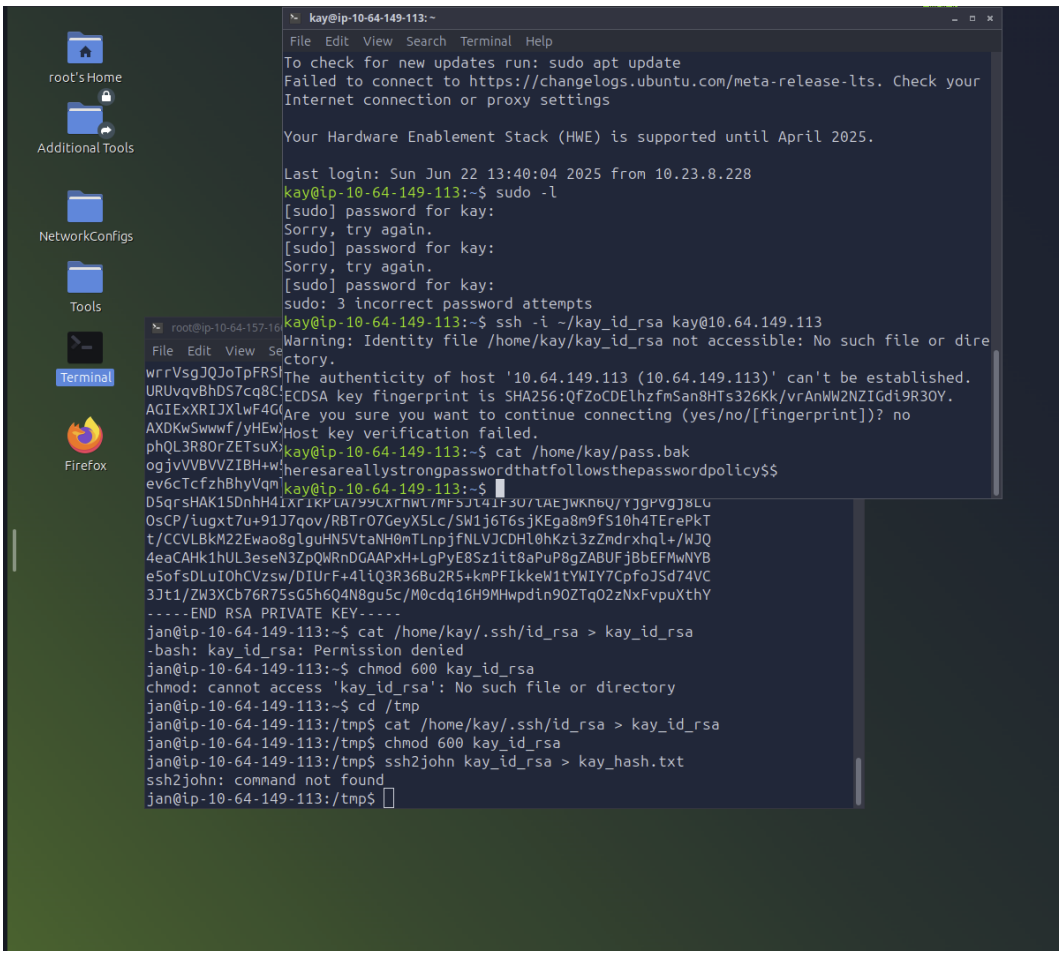


Figura 13: Contenido de `pass.bak`: contrasena final obtenida

Campo	Valor
Sala Basic Pentesting	Completada 100%
Contrasena final obtenida	`heresareallystrongpasswordthatfollowsthepasswordpolicy$$`

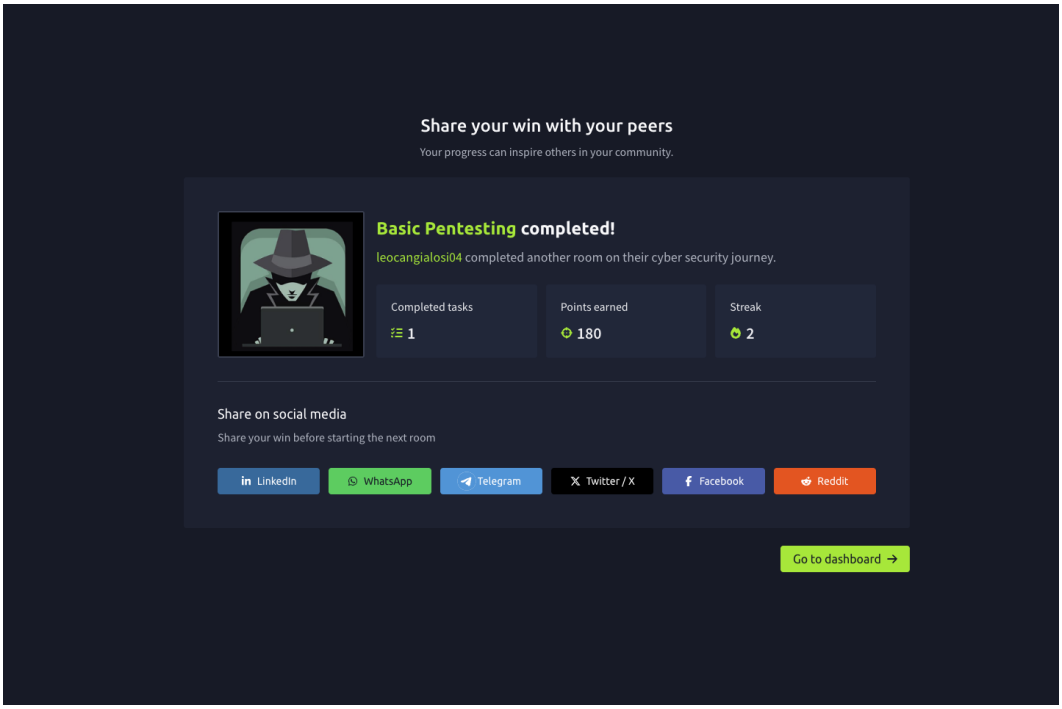


Figura 14: Sala Basic Pentesting completada al 100%

3.3. Sala de eleccion: Vulnversity

Sala completada al 100%. Objetivo: `10.64.171.15`.

Campo	Valor
ID del hallazgo	H-08
Fase	☐ Reconocimiento ■ Escaneo ☐ Explotacion ☐ Post-explotacion
Descripcion	Escaneo con Nmap revela 6 servicios expuestos: FTP (vsftpd 3.0.5), SSH, Samba (TCP/139 y 445), un proxy Squid 4.10 (TCP/3128) y un servidor Apache en un puerto no estandar (TCP/3333).
Componente afectado	`10.64.171.15` (puertos 21, 22, 139, 445, 3128, 3333)
Categoria (OWASP / CWE)	CWE-200
CVSS estimado	☐ Bajo ■ Medio ☐ Alto ☐ Critico

Evidencia (captura / comando)	`nmap -sV 10.64.171.15` — ver `bitacora/nmap_vulnversity.txt` y Figura 15
Herramienta utilizada	Nmap
Impacto en la Triada CIA	■ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Minimizar servicios expuestos, actualizar Squid y Apache a versiones soportadas, y ocultar banners de version.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

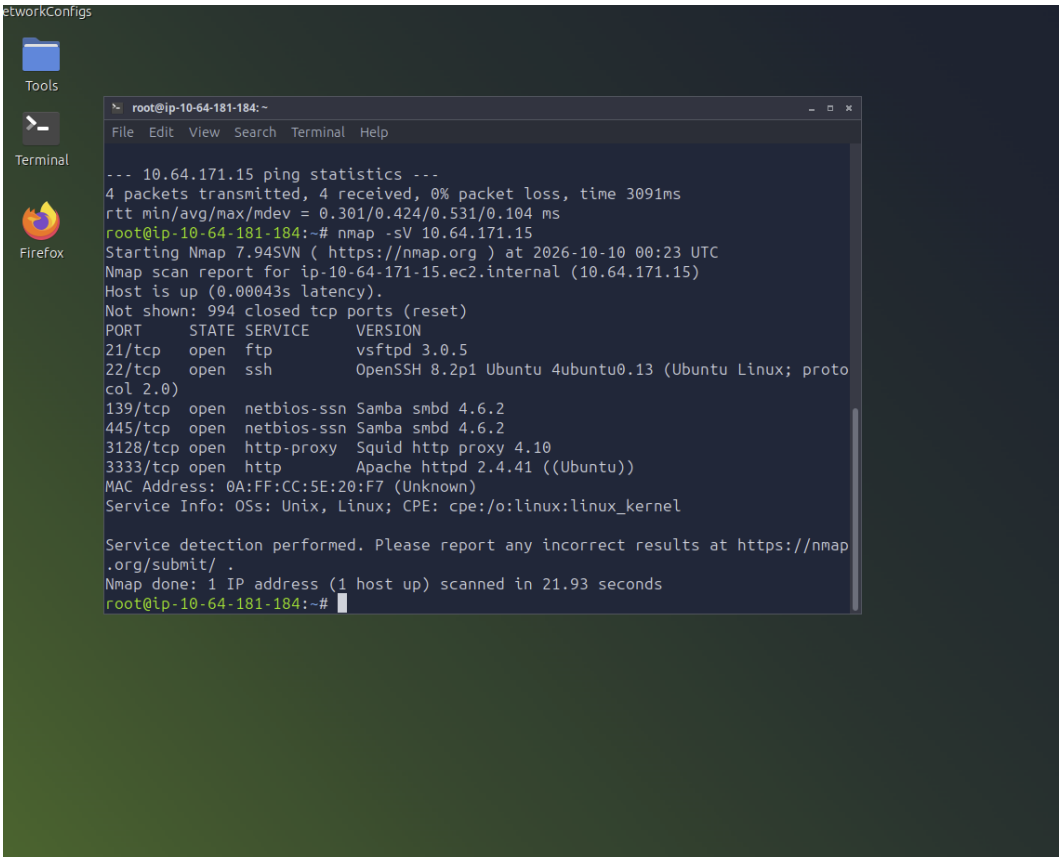


Figura 15: Resultado de Nmap sobre `10.64.171.15`: 6 puertos abiertos

Campo	**Valor**
ID del hallazgo	H-09
Fase	☐ Reconocimiento ☐ Escaneo ■ Explotacion ☐ Post-explotacion

Descripcion	La enumeracion de directorios con Gobuster sobre el puerto 3333 descubre `/internal`, una pagina con un formulario de carga de archivos sin autenticacion. El filtro de extensiones bloquea `.php` pero no `.phtml`, lo que permite subir y ejecutar un payload PHP (reverse shell) y obtener ejecucion remota de codigo como el usuario `www-data`.
Componente afectado	`http://10.64.171.15:3333/internal/`
Categoria (OWASP / CWE)	A05:2021 - Security Misconfiguration; CWE-434 (carga de archivo peligroso sin restriccion adecuada)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ■ Critico
Evidencia (captura / comando)	`gobuster dir -u http://10.64.171.15:3333 -w directory-list-1.0.txt`; payload PHP reverse shell renombrado a `.phtml` — ver `bitacora/nmap_vulnversity.txt`, `bitacora/vulnversity_resumen_ataque.txt` y Figuras 16–18
Herramienta utilizada	Gobuster, Netcat, payload PHP reverse shell
Impacto en la Triada CIA	■ Confidencialidad ■ Integridad ■ Disponibilidad
Salvaguarda propuesta	Validar extensiones por listas blancas (no negras), verificar el contenido real del archivo (magic bytes) en vez de la extension, y ejecutar el directorio de subidas sin permisos de ejecucion de scripts.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

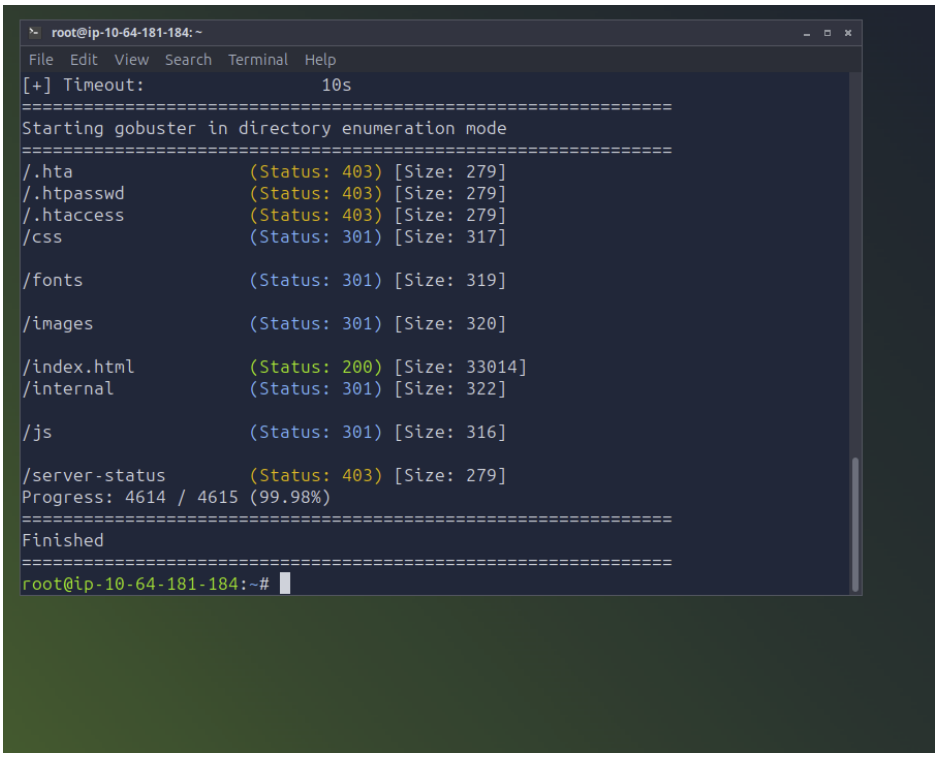


Figura 16: Gobuster descubre `/internal` en el puerto 3333

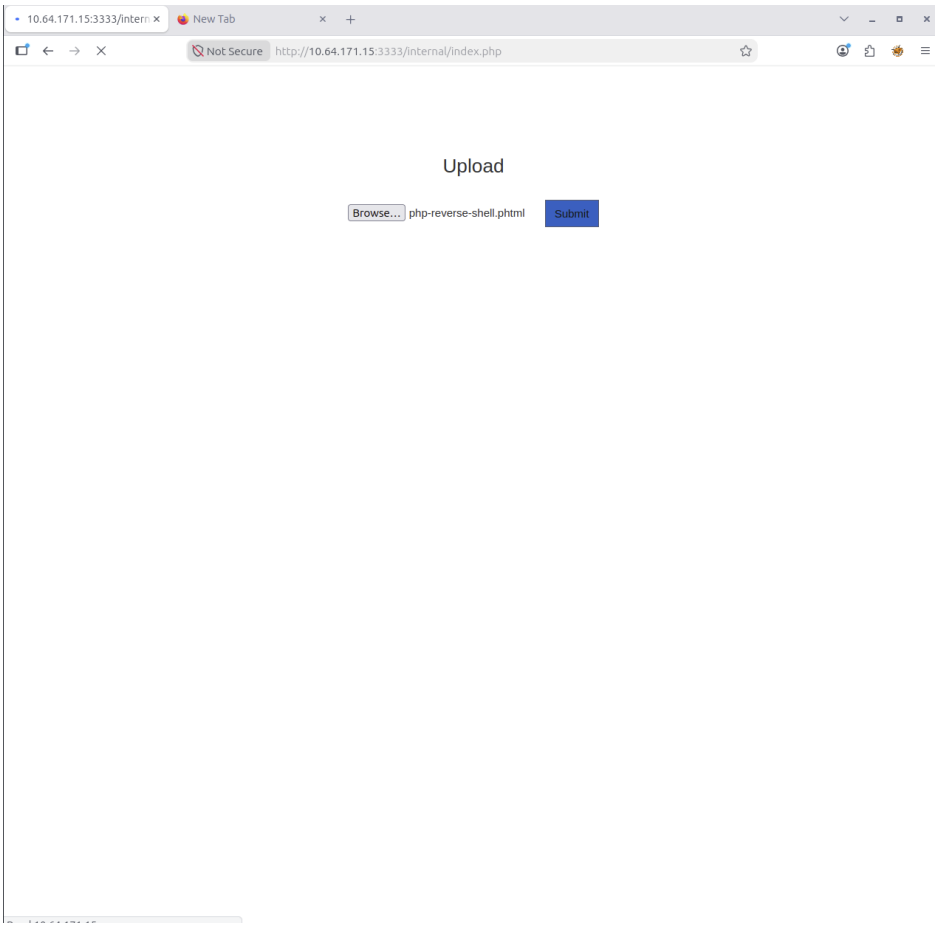


Figura 17: Formulario de carga de archivos en `/internal`

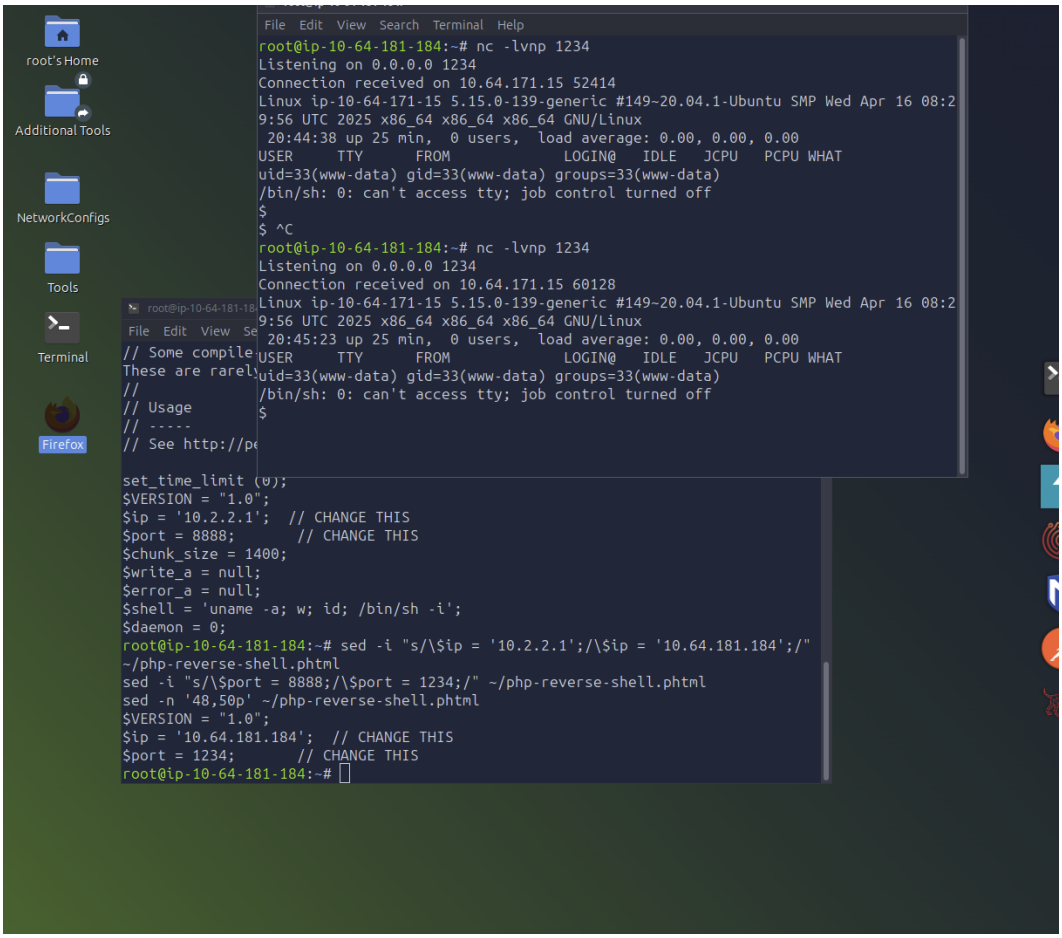


Figura 18: Reverse shell obtenida como `www-data`

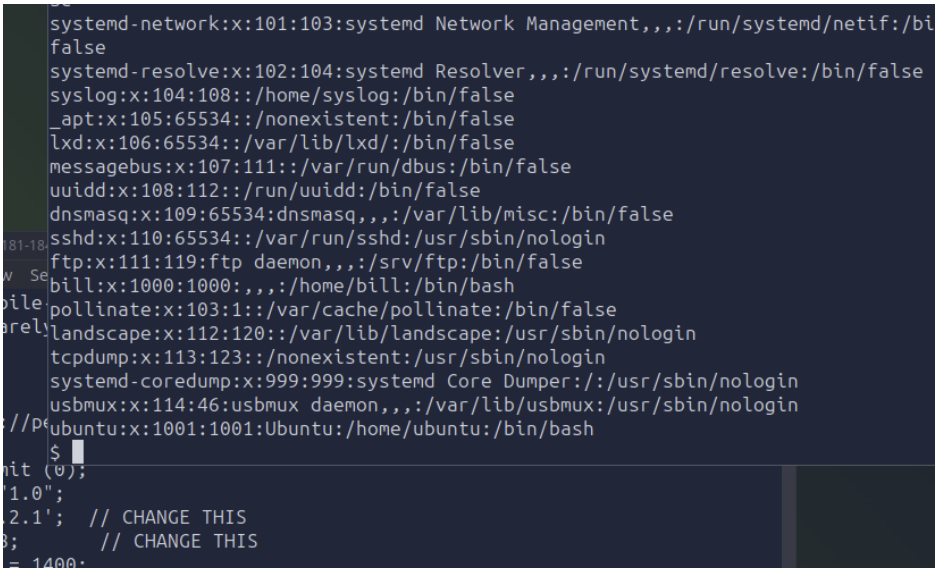


Figura 19: `/etc/passwd` revela al usuario real `bill`

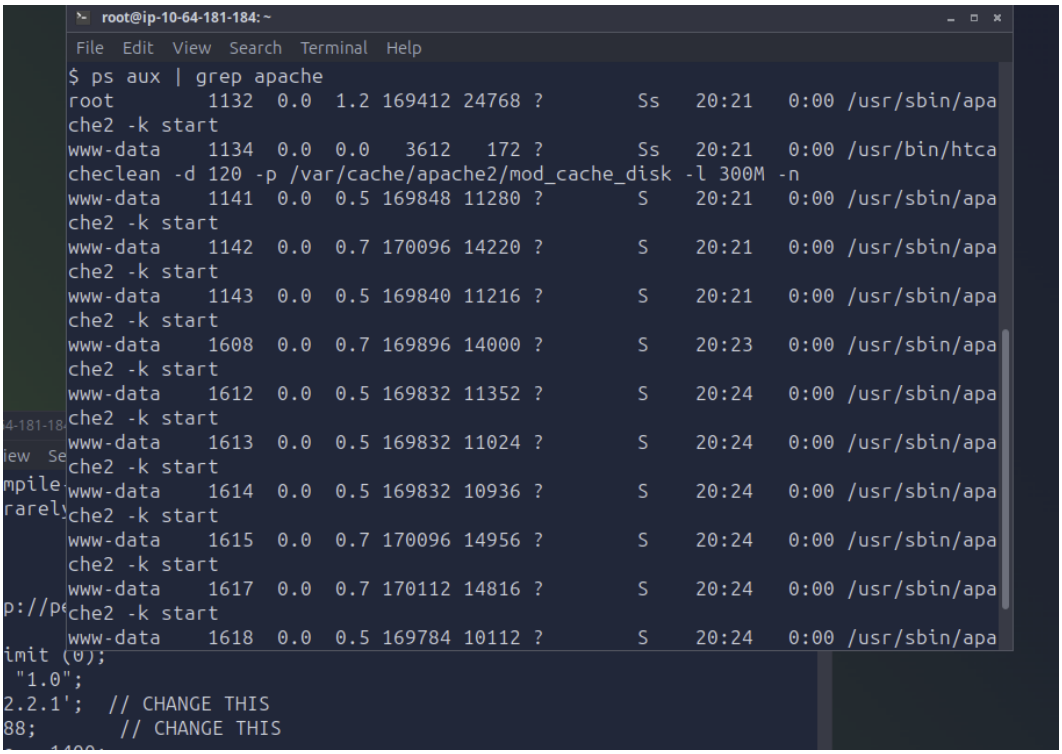


Figura 20: El proceso maestro de Apache corre como `root`; los procesos hijos como `www-data`

Campo	**Valor**
ID del hallazgo	H-10
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotacion ■ Post-explotacion
Descripcion	La enumeracion de binarios con bit SUID (`find / -perm -4000`) revela `/bin/systemctl` con el bit activado, algo no estandar en una instalacion limpia de Ubuntu. Se explota creando un servicio systemd temporal que, al habilitarse con `systemctl`, ejecuta `chmod +s /bin/bash` con privilegios de root, otorgando una shell de root completa.
Componente afectado	`/bin/systemctl` (bit SUID mal configurado)
Categoria (OWASP / CWE)	CWE-250 (ejecucion con privilegios innecesarios)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ■ Critico
Evidencia (captura / comando)	`find / -perm -4000 -type f`; explotacion via unidad systemd temporal (GTFOBins) — ver `bitacora/vulnversity_resumen_ataque.txt` y Figura 21
Herramienta utilizada	systemctl (GTFOBins)

Impacto en la Triada CIA	■ Confidencialidad ■ Integridad ■ Disponibilidad
Salvaguarda propuesta	Eliminar el bit SUID de binarios que no lo requieren (`chmod u-s /bin/systemctl`), auditar periodicamente binarios SUID/SGID contra una linea base conocida, y aplicar el principio de menor privilegio.
Riesgo residual tras aplicar	■ Bajo ☐ Medio ☐ Alto

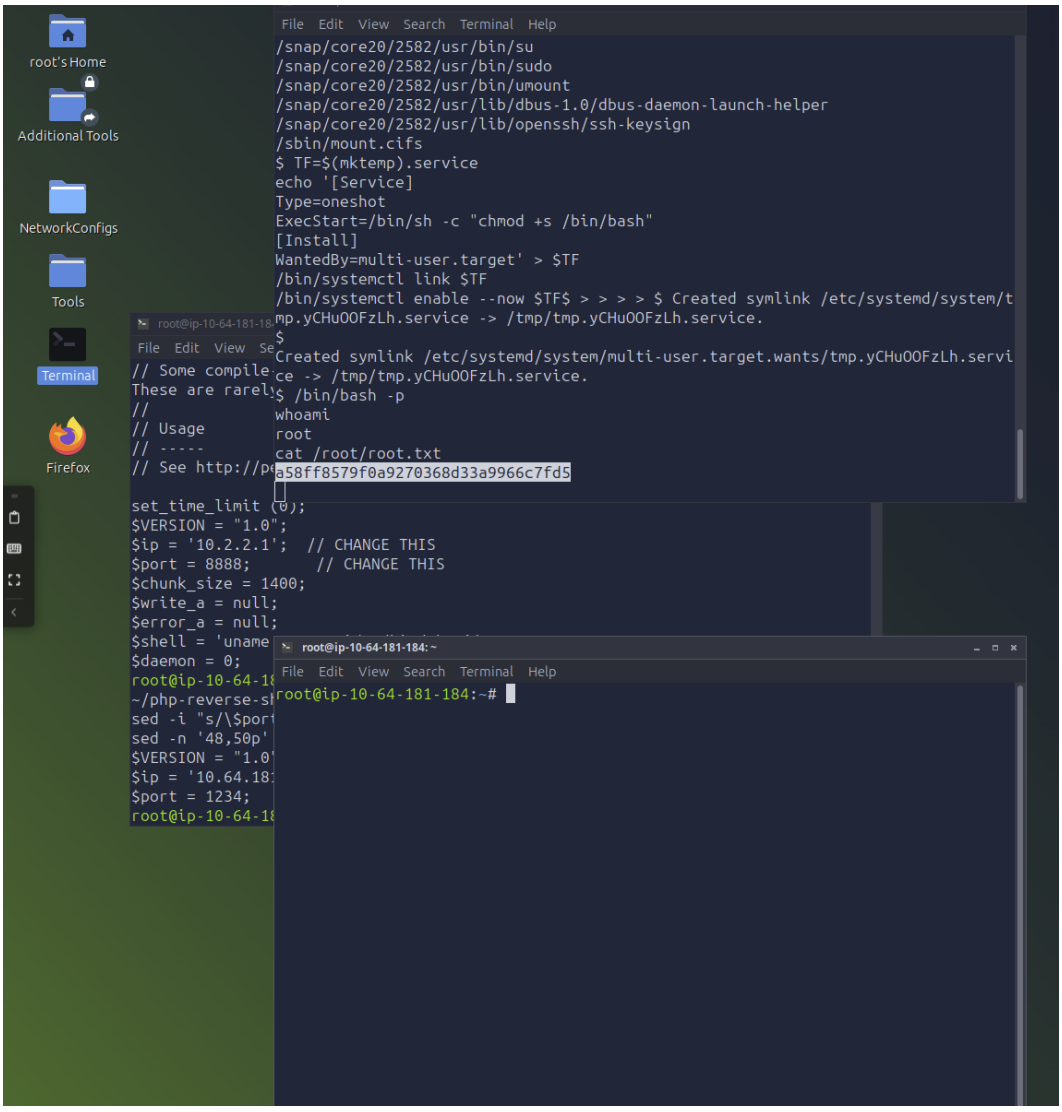


Figura 21: Escalada a root via `systemctl` SUID: `whoami` confirma `root` y se obtiene la flag

Campo	Valor
Sala Vulnversity	Completada 100%
Usuario que gestiona el webserver	`bill` (proceso maestro de Apache corre como root; usuario real del sistema: bill)
Root flag obtenida	`a58ff8579f0a9270368d33a9966c7fd5`

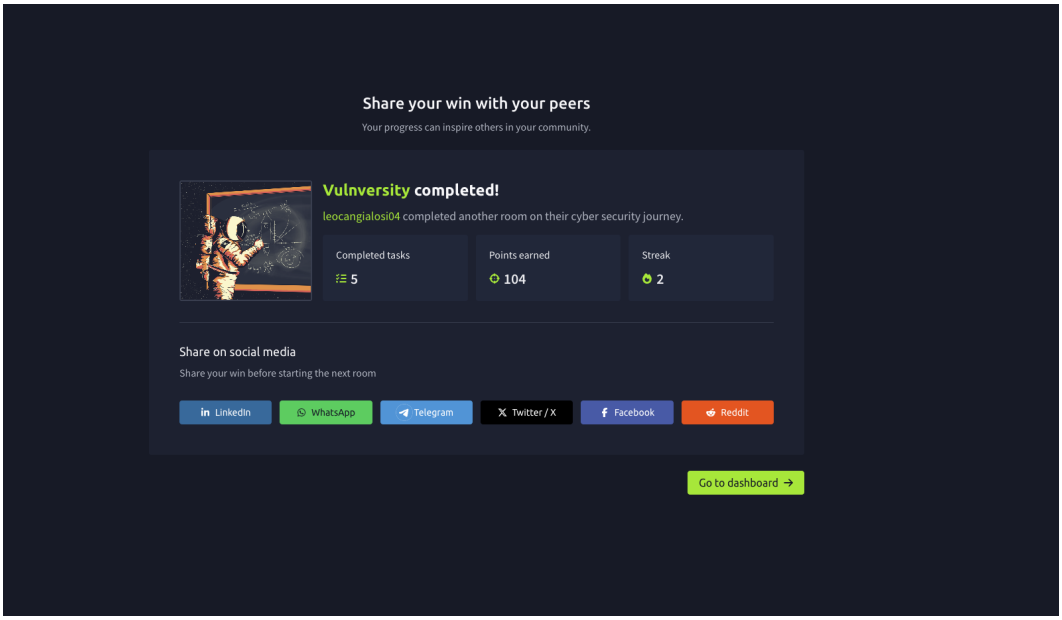


Figura 22: Sala Vulnversity completada al 100%

4. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Critico	4	H-04, H-06, H-09, H-10
Alto	3	H-03, H-05, H-07
Medio	2	H-02, H-08
Bajo	1	H-01
Total	10	H-01 a H-10 (Pentesting Fundamentals, Basic Pentesting y Vulnversity completas)

5. Post-pentesting: Recomendaciones

Recomendaciones tecnicas (parches y configuraciones)

Completar en base a los hallazgos reales: actualizacion de versiones de servicios vulnerables, cierre de puertos innecesarios, endurecimiento de permisos SUID/SGID, politicas de contrasenas, etc.

Recomendaciones administrativas (politicas y procesos)

Politicas de actualizacion periodica, capacitacion del personal, revisiones de seguridad programadas, gestion de parches.

6. Protocolo de contingencia

Escenario de falla

Si las tecnicas de explotacion aplicadas en el laboratorio (p. ej. ejecucion remota de codigo sobre un servicio FTP/HTTP vulnerable, o escalada de privilegios via binarios SUID) se replicaran por error o de forma malintencionada sobre un servidor de produccion de INSECUR S.A., podria ocasionarse la caida del servicio afectado, corrupcion de datos o acceso no autorizado con privilegios de administrador.

Impacto sobre la continuidad del negocio

Completar: que procesos de INSECUR S.A. dependen del servicio comprometido (por ejemplo, el sitio web publico o el servidor de archivos) y por cuanto tiempo se veria interrumpida la operacion si no se actua a tiempo.

Plan de respuesta

1. **Activacion:** deteccion mediante monitoreo de logs y alertas de IDS/antivirus ante trafico o procesos anomalos.
2. **Contencion (primeros 15 minutos):** aislar el servidor afectado de la red, revocar credenciales comprometidas, preservar evidencia forense.
3. **Recuperacion:** restaurar el servicio desde el ultimo backup verificado o levantar el servidor espejo; aplicar el parche correspondiente antes de reconectar a produccion.
4. **Comunicacion:** notificar a direccion de INSECUR S.A. y, si corresponde por el tipo de dato afectado, a las autoridades competentes y a los clientes impactados.
5. **Post-mortem:** documentar la cronologia del incidente, causa raiz y acciones correctivas; actualizar el plan de contingencia con lo aprendido.

RTO y RPO estimados

RTO (Recovery Time Objective): .....
RPO (Recovery Point Objective): .....

7. Anexos

Anexo A — Bitacora de comandos

Ver archivos `bitacora/*.txt` en esta branch.

Anexo B — Capturas de pantalla

Ver carpeta `evidencias/` organizada por fase (reconocimiento, escaneo, explotacion, post).

Anexo C — Hashes de las flags obtenidas

```
# Formato: flag_id  sha256_hash
F-01 (Pentesting Fundamentals, practico ACME)
  583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6

F-02 (Basic Pentesting, password final de kay / pass.bak)
  Credencial en texto plano hallada durante H-07; no se publica en
  este anexo por tratarse de una contrasena de cuenta real de la
  maquina victima (ver hallazgo H-07 para el detalle completo).

F-03 (Vulnversity, root flag)
  cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
```

Anexo D — Declaracion etica firmada

Declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados y con fines exclusivamente academicos.

_____ _____

Leonardo Cangialosi Fecha